SIEM

Security Information & Event Management

مصادر الـ Logs (Log Sources)

كل جهاز في الشبكة يولد Logs، وتنقسم مصادرها إلى نوعين رئيسيين: مصادر داخل الجهاز ومصادر على مستوى الشبكة.

🌐 Network-Centric (على الشبكة)

تسجيل الاتصالات وما يحدث بين الأجهزة.

- اتصالات VPN
- حركة مرور الويب (Web Traffic)
- اتصالات SSH
- مشاركة الملفات (File Sharing)

المصادر: Router • IDS/IPS • Firewall

🖥️ Host-Centric (داخل الجهاز)

تسجيل كل ما يحدث داخل الجهاز نفسه.

- تسجيل دخول مستخدم (نجاح/فشل)
- تشغيل برامج وعمليات
- تشغيل PowerShell

المصادر: Windows • Linux • Server

مشاكل تحليل Logs بدون SIEM

تحليل الـ Logs يدويًا بدون SIEM يواجه تحديات جسيمة تجعل اكتشاف الهجمات شبه مستحيل.

⚠️ High Volume of Logs

كل جهاز يولد مئات من الـ Logs يوميًا.

⚠️ Lack of Centralization

كل جهاز يحتفظ بـ Logs منفصلة، تحتاج RDP (3389) أو SSH (22) للوصول إليها.

⚠️ Limited Context

الحدث لوحده يبدو طبيعيًا، لكن ربط الأحداث ببعضها يكشف الهجوم.

⚠️ Different Formats

كل جهاز له Format مختلف مما يصعّب التحليل الموحد.

لماذا SIEM؟ (Why SIEM?)

نظام SIEM يحل جميع تحديات تحليل الـ Logs من خلال منظومة متكاملة من الأدوات والميزات.

Centralization

جمع وتوحيد الـ Format (Normalizing) باستخدام Agent أو APIs.

Threat Detection

كشف الهجوم وإعطاء Alerts بناءً على IP، User، والـ Action.

Dashboards + Reports

عرض معلومات مثل Action، Severity، والـ Alert بصريًا.

Correlation & Real-time Alerting

ربط الأحداث من مصادر مختلفة وإعطاء Real-time Alerts عبر Rules.

[redacted]

أين تُحفظ الأحداث؟ (Event Storage)

🖥️ Windows

تُحفظ في **Event Viewer**

يعتمد على **Event ID** لتحديد نوع الحدث.

🐧 Linux

تُحفظ في `/var/log/`

- `auth.log` ← تسجيل الدخول
- `kern/` ← الـ Kernel
- `cron/` ← المهام المجدولة

🌐 Web Servers

`/var/log/apache/` أو `/var/log/httpd/`

للكشف عن هجمات مثل **SQL Injection** و**Brute Force**.

- **طريقة الطلب:** GET / POST
- **المستخدم:** تحديد مصدر الطلب **IP**
- **Status Code:** تحديد نتيجة الطلب
- **الصفحة المطلوبة:** تتبع النشاط على الموقع

Log Ingestion — كيف توصل الـ Logs للـ SIEM؟

1

Agent / Forwarder

تطبيق صغير يُثبت على الجهاز لجمع الـ Logs مثل **Splunk Forwarder**.

2

Syslog

بروتوكول مشهور ومعتمد على نطاق واسع لإرسال الـ Logs.

3

Manual Upload

رفع ملف الـ Logs بشكل يدوي مباشرةً إلى الـ SIEM.

4

Port Forwarding

الـ SIEM يفتح Port والجهاز يرسل الـ Logs إليه مباشرةً.

Detection Rules — قواعد الكشف

ما هي القاعدة؟

شروط منطقية (Logical Conditions) تراقب الـ Logs وتُبنى بصيغة **Field = Value** وتعتمد على Log Source، IP، User، و Event ID.

Use Case 1: Logs Cleared

المهاجم يحاول إخفاء الأثر.

Log Source=WinEventLog AND EventID=104

Alert: **Logs Cleared** 👉

Use Case 2: Suspicious Command

تنفيذ أمر whoami بعد الاختراق.

EventID=4688 AND "ProcessName="whoami

Alert: **Suspicious Command Execution** 👉

أنواع التنبيهات (Alerts) وعملية الـ Tuning

بعد ظهور التنبيه يتم عمل Tuning للتفريق بين الهجوم الحقيقي والنشاط الطبيعي.

1. ✅ **True Positive (TP)**

   يوجد Alert **ويوجد** Attack فعلي — هذا هو الهدف المطلوب.

2. ❌ **False Positive (FP)**

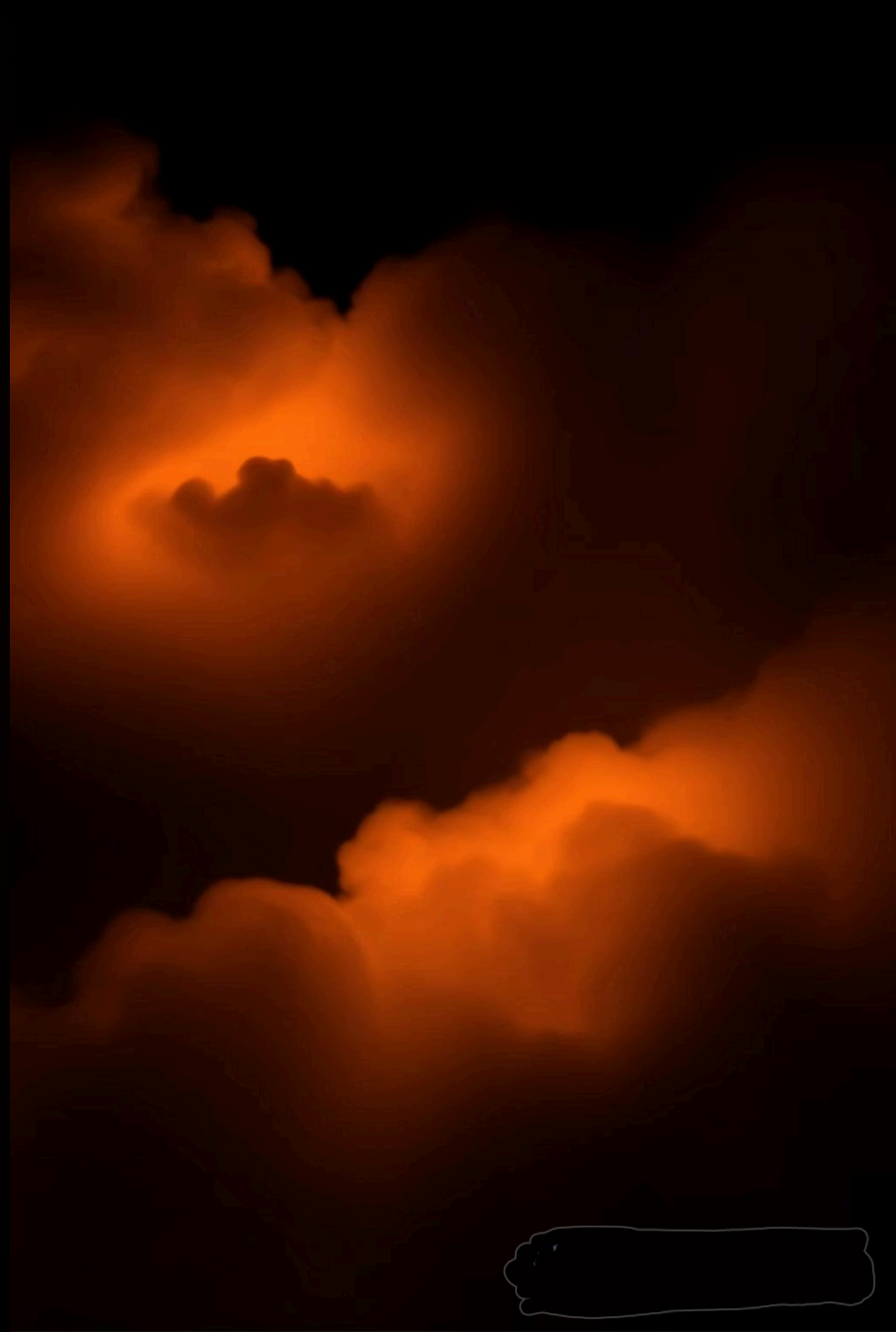
   يوجد Alert لكنه **نشاط طبيعي** وليس هجومًا حقيقيًا — يحتاج Tuning.

3. ❗ **False Negative (FN)**

   لا يوجد Alert مع وجود Attack فعلي — وهو **أخطر نوع** على الإطلاق.

4. ⚠️ **True Negative (TN)**

   لا يوجد Alert **والوضع طبيعي** — النظام يعمل بشكل صحيح.



Change Management & Adoption

نشر SIEM يتطلب فهم المفاهيم الأساسية وتطبيق الـ Rules بدقة لضمان الكشف الفعّال عن التهديدات.

جمع الـ Logs

Manual Upload أو Syslog أو Agent

بناء الـ Rules

تعريف Conditions بناءً على Field = Value

مستمر Tuning

تقليل False Positives وتعزيز True Positives

نظام SIEM الفعّال يعتمد على دورة مستمرة من جمع البيانات وبناء القواعد وضبطها للحفاظ على دقة الكشف عن التهديدات الحقيقية.

ملخص SIEM

أنواع التنبيهات

TP / FP / FN / TN

للتفريق بين الهجوم والنشاط الطبيعي Tuning

قواعد الكشف

Detection Rules

بناءً على EventID، User، IP Field=Value

Log Ingestion

4 طرق للإرسال

Agent • Syslog • Manual • Port Forwarding

لماذا SIEM؟

مركزية + ربط + تنبيه فوري

الحل الشامل لتحليل الـ Logs وكشف الهجمات